Informe de Pentesting: Máquina TryHeartMe (TryHackMe)

Autor: Samir Sbdiel Rojas Tamara (Craxker) **Plataforma:** TryHackMe **Objetivo:** 10.66.141.238

1. Resumen ejecutivo

Se realizó una evaluación de seguridad sobre la máquina **TryHeartMe** de TryHackMe, una tienda web construida en Python/Flask (Werkzeug). El objetivo consistió en identificar servicios expuestos, enumerar rutas ocultas de la aplicación, acceder al panel de administración y capturar la flag final, ubicada en un recibo de compra de un artículo exclusivo del portal de administración.

La flag obtenida fue:

`THM{v4l3nt1n3_jwt_c00k13_t4mp3r_4dm1n_sh0p}`

El propio nombre de la flag (*jwt_cookie_tamper_admin_shop*) indica que la vía de explotación fue la **manipulación de una cookie/token JWT de sesión** para escalar privilegios de usuario normal a administrador.

2. Reconocimiento inicial

2.1 Verificación de conectividad (ping)

Se comprobó que el host estaba activo mediante ICMP:

```
ping 10.66.141.238 -c3
```

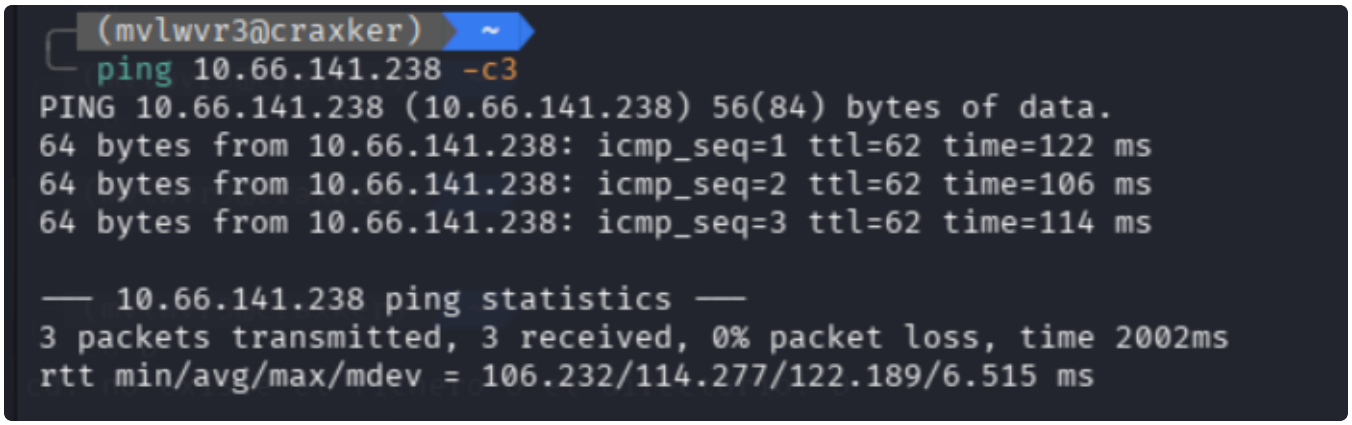
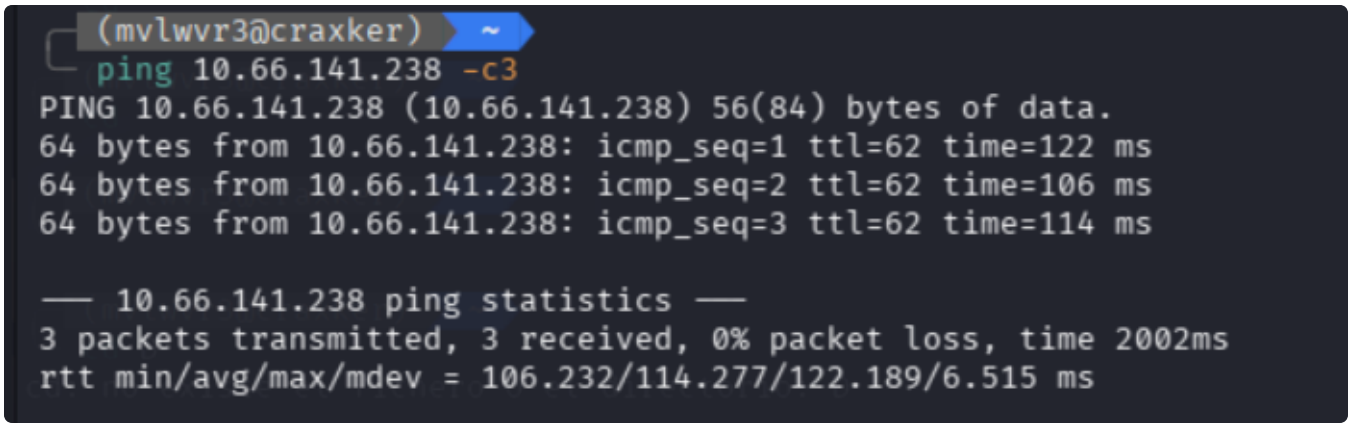


Figura 1: Verificación de conectividad hacia 10.66.141.238 mediante ping ICMP.

Resultado: 3 paquetes enviados, 3 recibidos, 0% de pérdida, con un RTT promedio de ~114 ms. Esto confirmó que la máquina objetivo estaba en línea y accesible desde la red del atacante.



2.2 Escaneo de puertos y servicios (nmap)

Se ejecutó un escaneo agresivo para identificar puertos abiertos, servicios y versión del sistema operativo:

```
nmap -A 10.66.141.238
```

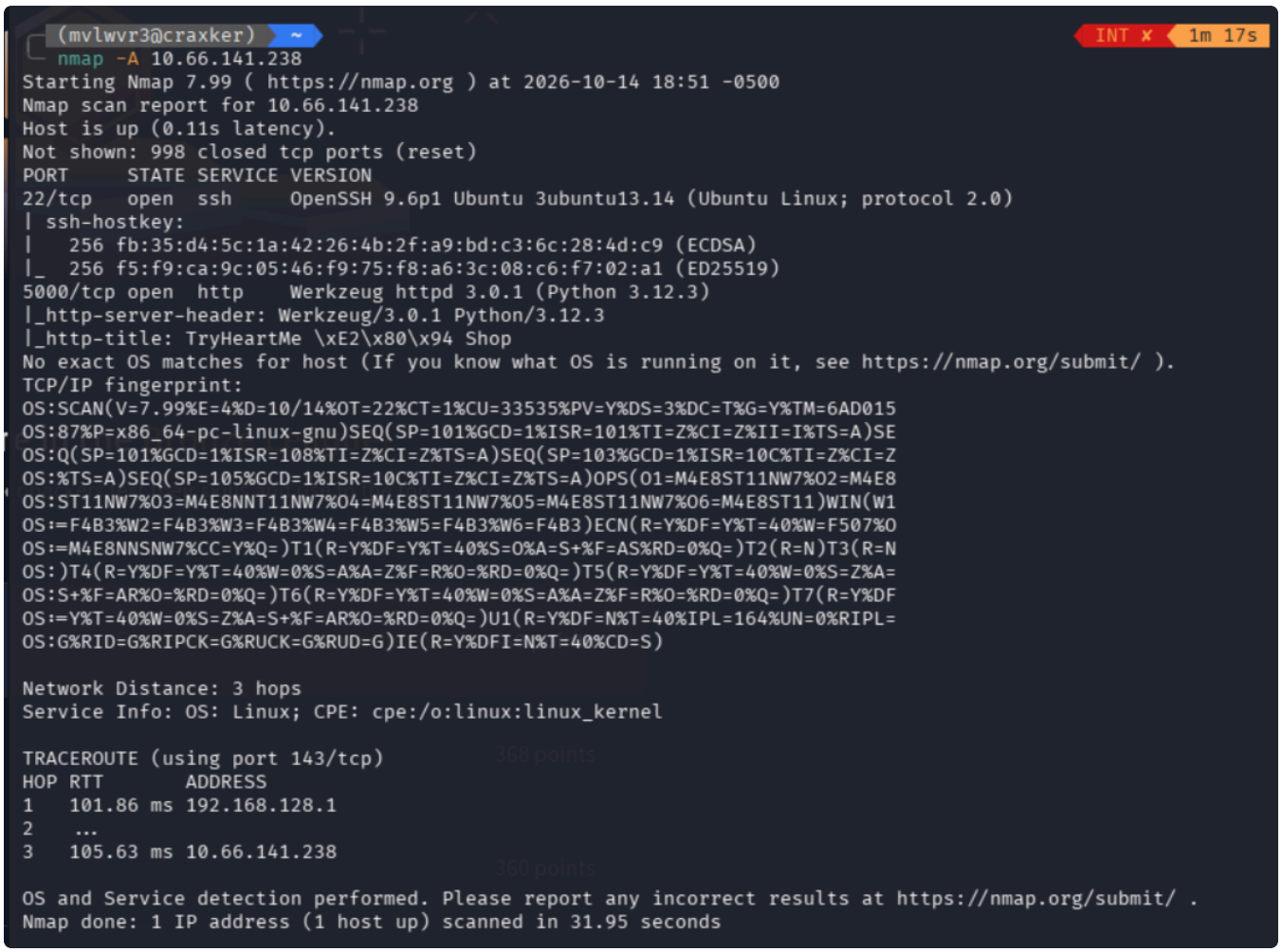


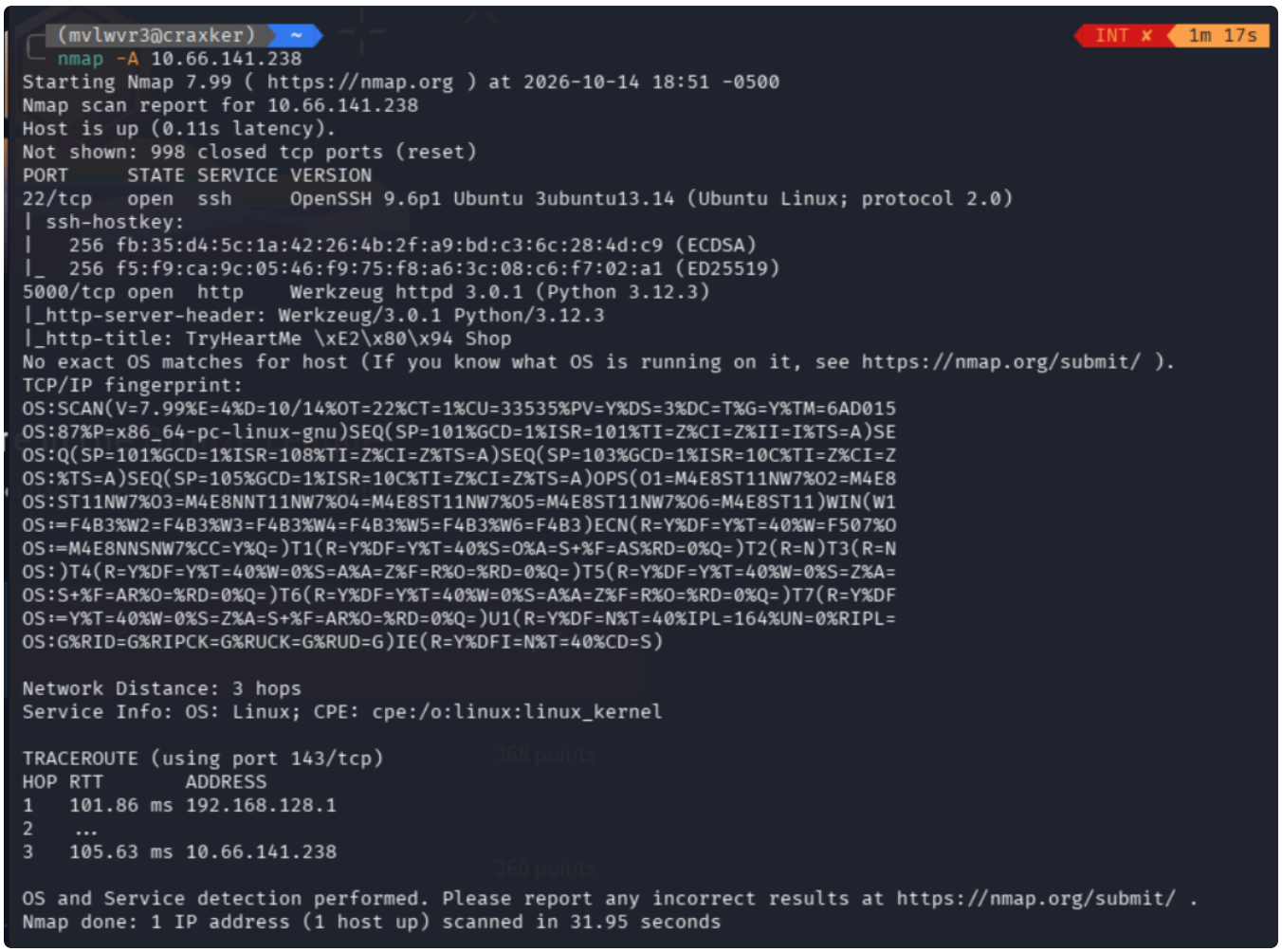
Figura 2: Escaneo de puertos y servicios con nmap -A sobre 10.66.141.238.

Hallazgos principales:

Puerto	Estado	Servicio	Versión
22/tcp	open	ssh	OpenSSH 9.6p1 (Ubuntu)
5000/tcp	open	http	Werkzeug httpd 3.0.1 (Python 3.12.3)

- El título de la página web detectado fue **"TryHeartMe — Shop"**.
- El sistema operativo identificado por huella TCP/IP fue **Linux**.
- La ruta de red mostró 3 saltos (traceroute), confirmando que el objetivo se encontraba detrás de un salto intermedio (192.168.128.1).

Esto estableció que el vector de ataque principal sería la aplicación web Flask corriendo en el puerto 5000, dejando SSH (22) como un servicio secundario no explotado directamente en esta fase.



```
(mvlwvr3@craxker) ~                                                    INT ✘  1m 17s
nmap -A 10.66.141.238
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-14 18:51 -0500
Nmap scan report for 10.66.141.238
Host is up (0.11s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 fb:35:d4:5c:1a:42:26:4b:2f:a9:bd:c3:6c:28:4d:c9 (ECDSA)
|_  256 f5:f9:ca:9c:05:46:f9:75:f8:a6:3c:08:c6:f7:02:a1 (ED25519)
5000/tcp open  http    Werkzeug httpd 3.0.1 (Python 3.12.3)
|_http-server-header: Werkzeug/3.0.1 Python/3.12.3
|_http-title: TryHeartMe \xE2\x80\x94 Shop
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=10/14%OT=22%CT=1%CU=33535%PV=Y%DS=3%DC=T%G=Y%TM=6AD015
OS:87%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=101%TI=Z%CI=Z%II=I%TS=A)SE
OS:Q(SP=101%GCD=1%ISR=108%TI=Z%CI=Z%TS=A)SEQ(SP=103%GCD=1%ISR=10C%TI=Z%CI=Z
OS:%TS=A)SEQ(SP=105%GCD=1%ISR=10C%TI=Z%CI=Z%TS=A)OPS(O1=M4E8ST11NW7%O2=M4E8
OS:ST11NW7%O3=M4E8NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1
OS:=F4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O
OS:=M4E8NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N
OS:)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=
OS:S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF
OS:=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=
OS:G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 143/tcp)
HOP RTT       ADDRESS
1   101.86 ms 192.168.128.1
2   ...
3   105.63 ms 10.66.141.238

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.95 seconds
```

3. Enumeración de la aplicación web

3.1 Verificación del servicio HTTP (curl)

Se realizó una petición directa a la raíz del sitio para confirmar la respuesta del servidor:

```
curl -i http://10.66.141.238:5000/
```

```
(mvlwvr3@craxker) ~                                                    ✔ 32s
curl -i http://10.66.141.238:5000/
HTTP/1.1 200 OK
Server: Werkzeug/3.0.1 Python/3.12.3
Date: Wed, 14 Oct 2026 23:53:01 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 3351
Connection: close

<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1" />
  <title>TryHeartMe — Shop</title>
  <link rel="stylesheet" href="/static/css/style.css">
  <script defer src="/static/js/app.js"></script>
</head>
<body>
<header class="topbar">
  <a class="brand" href="/">
    <img class="brand-mark" src="/static/img/logo.png" alt="TryHeartMe">
  </a>

    <nav class="nav">
      <a href="/" class="navlink">Shop</a>

        <a href="/login" class="navbtn navbtn--pill">Login</a>
```

Figura 3: Respuesta HTTP obtenida mediante curl -i sobre el puerto 5000.

La respuesta fue `HTTP/1.1 200 OK`, servida por `Werkzeug/3.0.1 Python/3.12.3`, devolviendo el HTML de la tienda **TryHeartMe**, con una barra de navegación que incluía los enlaces **Shop** y **Login**.


```
(mvlwvr3@craxker) ~                                                    ✔ 32s
curl -i http://10.66.141.238:5000/
HTTP/1.1 200 OK
Server: Werkzeug/3.0.1 Python/3.12.3
Date: Wed, 14 Oct 2026 23:53:01 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 3351
Connection: close

<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1" />
  <title>TryHeartMe — Shop</title>
  <link rel="stylesheet" href="/static/css/style.css">
  <script defer src="/static/js/app.js"></script>
</head>
<body>
<header class="topbar">
  <a class="brand" href="/">
    <img class="brand-mark" src="/static/img/logo.png" alt="TryHeartMe">
  </a>

    <nav class="nav">
      <a href="/" class="navlink">Shop</a>

        <a href="/login" class="navbtn navbtn--pill">Login</a>
```

3.2 Descubrimiento de directorios (gobuster)

Para identificar rutas no enlazadas visiblemente en la interfaz, se ejecutó fuerza bruta de directorios:

```
gobuster dir -u http://10.66.141.238:5000/ -w
/usr/share/wordlists/dirb/common.txt
```

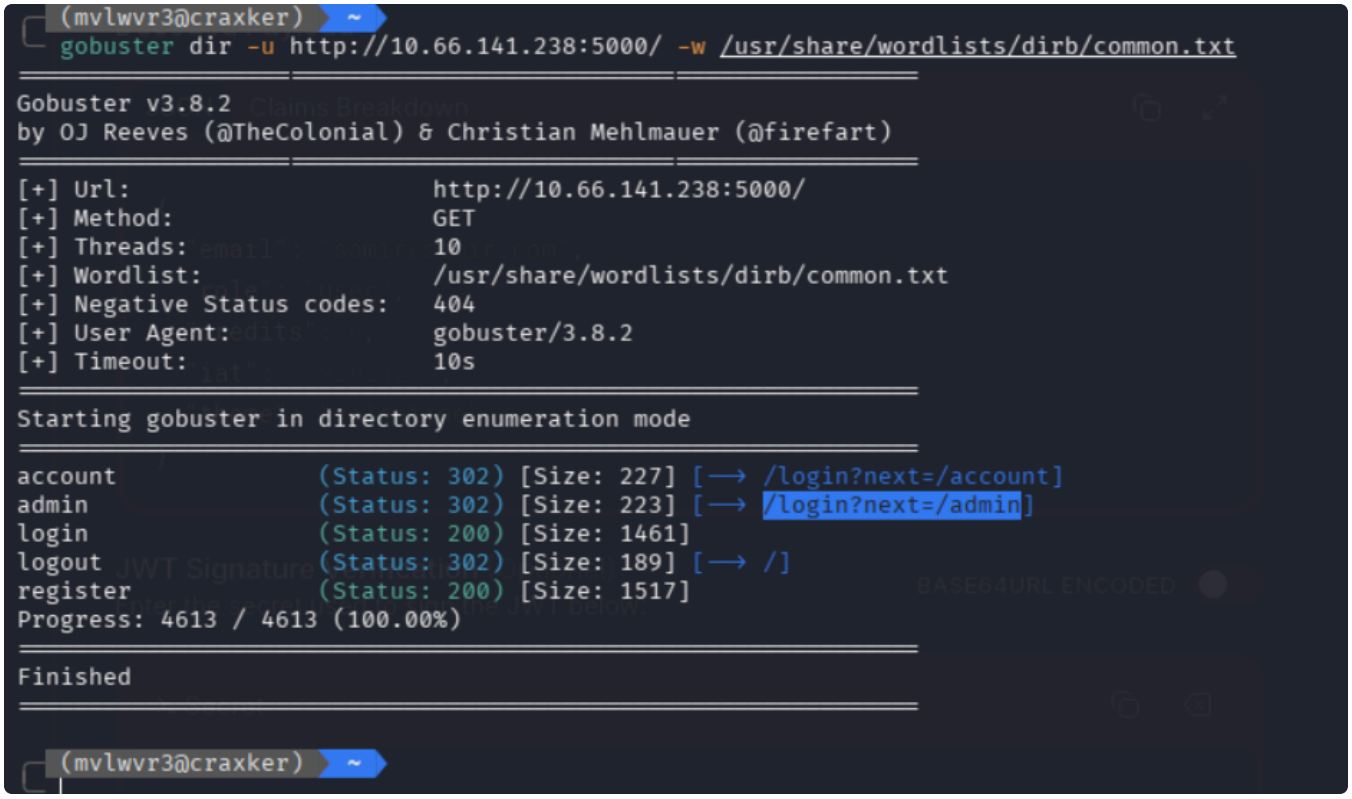
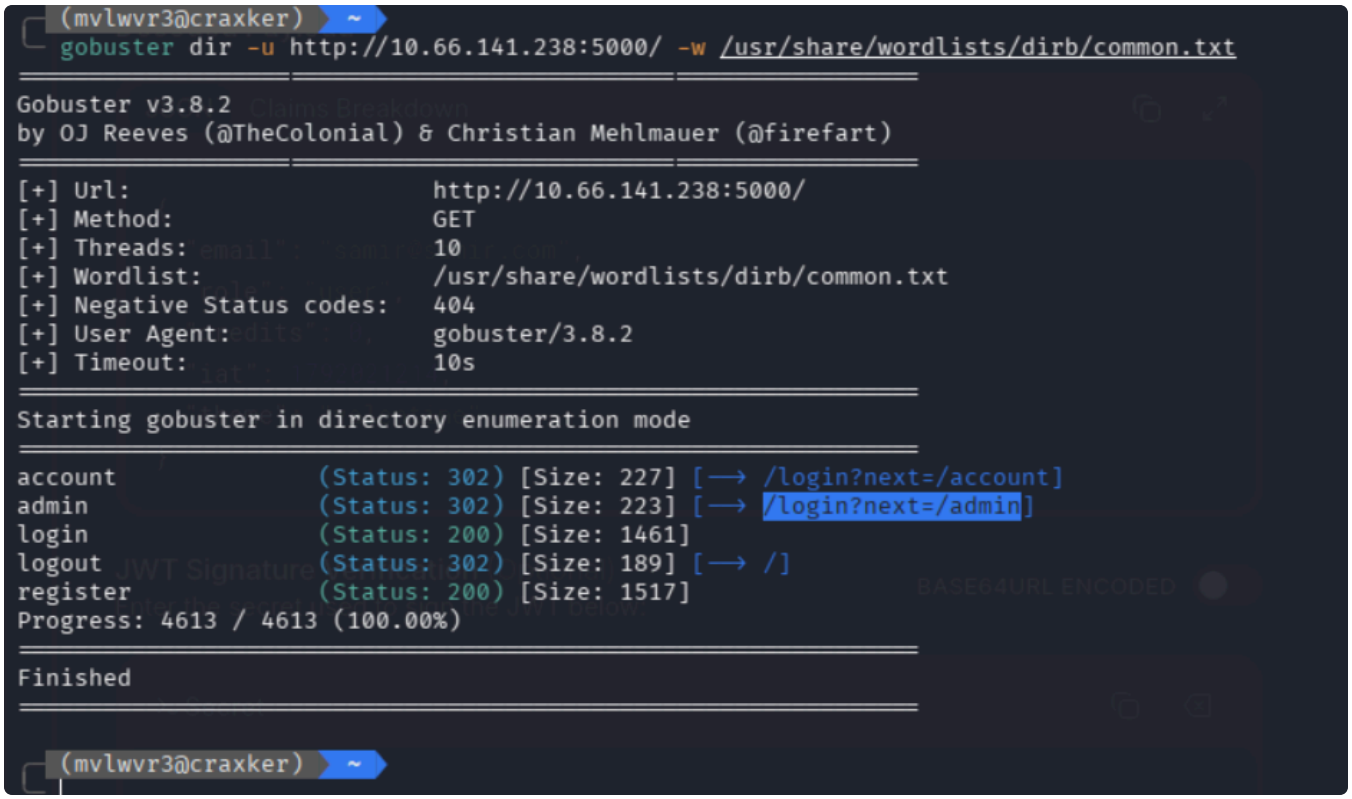


Figura 4: Enumeración de directorios con gobuster — hallazgo de la ruta /admin.

Rutas encontradas:

Ruta	Estado	Redirección
/account	302	/login?next=/account
/admin	302	/login?next=/admin
/login	200	—
/logout	302	/
/register	200	—

El hallazgo clave fue la ruta **/admin**, protegida por autenticación (redirigía a login), lo que confirmó la existencia de un panel administrativo como objetivo de escalada de privilegios.



4. Acceso al panel de administración y explotación

A partir de la ruta `/admin` identificada, se obtuvo acceso al **Portal de administración** autenticado como `samir@samir.com`, con **Rol: admin** y **Créditos: 99999**.

> Nota: las capturas disponibles no documentan el paso intermedio de autenticación/escalada (registro de usuario, login inicial y la manipulación del token de sesión). Sin embargo, el nombre de la flag final (*jwt_cookie_tamper*) indica que el acceso administrativo se logró alterando el contenido de una cookie JWT de sesión, muy probablemente modificando el campo de rol (de usuario normal a `admin`) y/o el saldo de créditos antes de que el servidor validara la firma o la confiara sin verificación adecuada.

El panel de administración mostró una sección **"Compra solo de personal"**, indicando que el artículo **ValenFlag** solo es visible y comprable por cuentas con rol de personal/administrador, e imprime un recibo con un vale al adquirirlo.

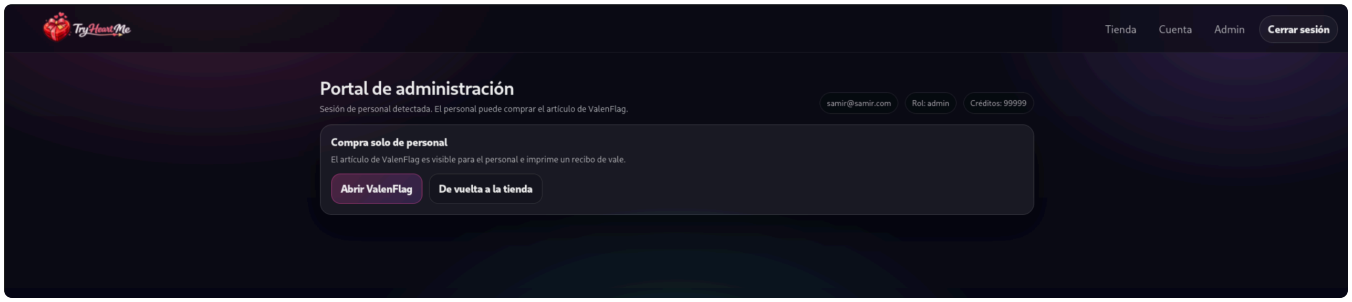
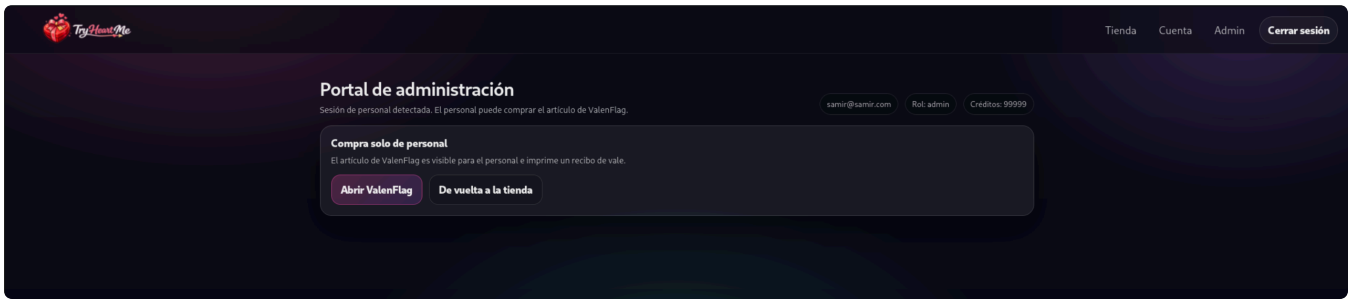


Figura 5: Acceso al portal de administración como samir@samir.com (Rol: admin, 99999 créditos).



5. Explotación: compra del artículo ValenFlag

Desde el panel admin se accedió al producto exclusivo:

```
http://10.66.141.238:5000/product/valenflag
```

La página mostró:

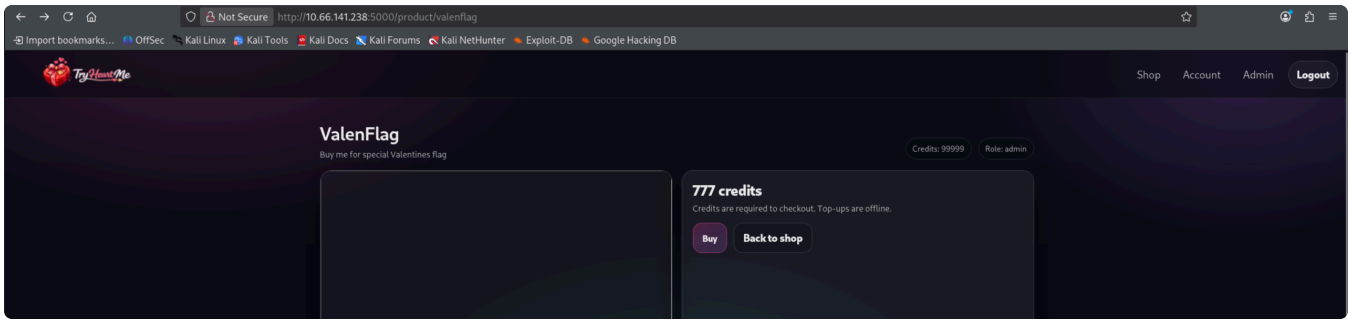
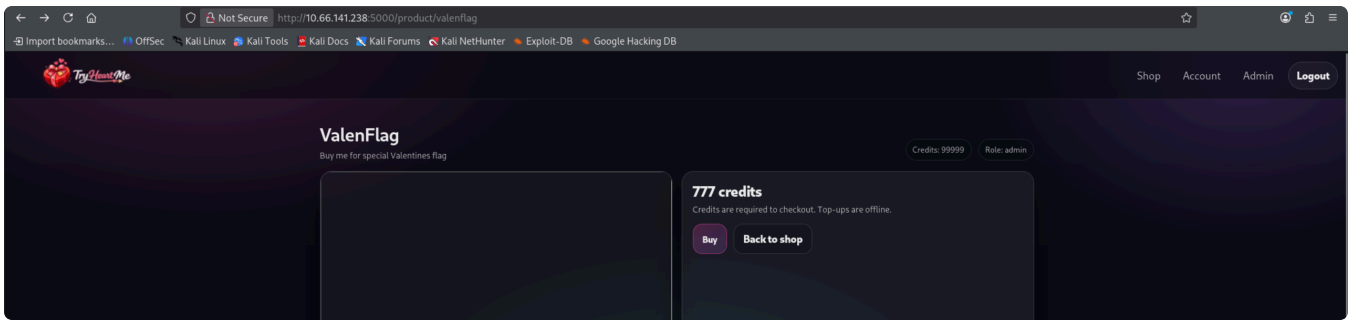


Figura 6: Página del producto exclusivo ValenFlag (777 créditos, Rol: admin).

- **Producto:** ValenFlag — "Buy me for special Valentines flag"
- **Precio:** 777 créditos
- **Créditos disponibles:** 99999 (Rol: admin)

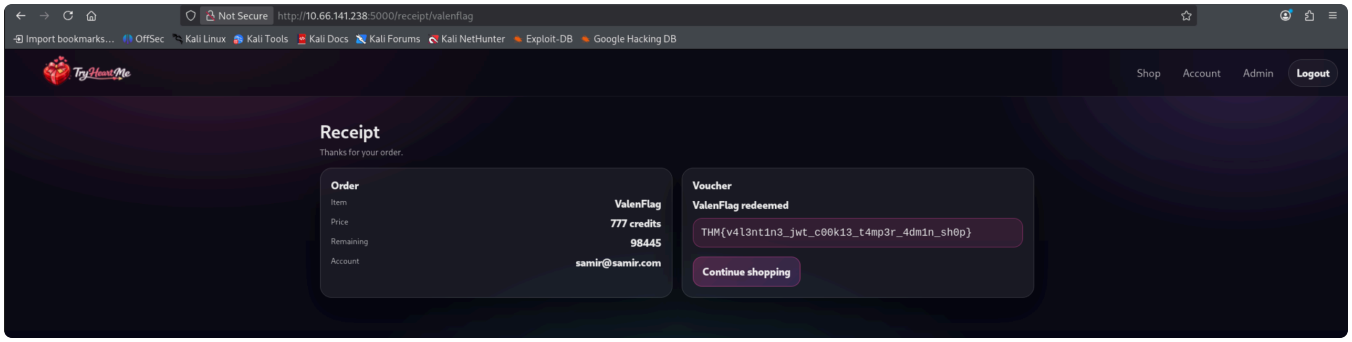


Se efectuó la compra (botón **Buy**), redirigiendo al recibo de la transacción.

6. Captura de la flag

En la página de recibo:

```
http://10.66.141.238:5000/receipt/valenflag
```



Se mostró el detalle de la orden:

Campo	Valor
Item	ValenFlag
Precio	777 créditos
Restante	98445
Cuenta	samir@samir.com

Y el vale ("Voucher") entregado contenía la flag:

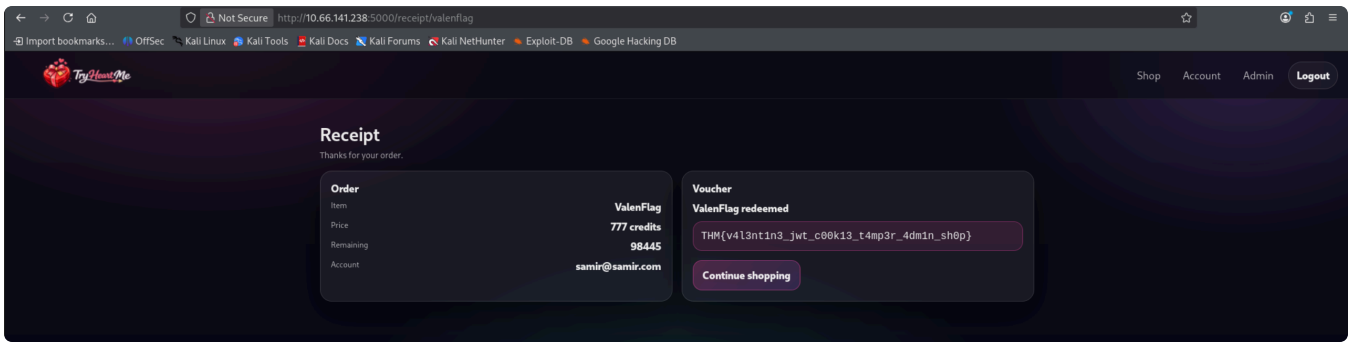


Figura 7: Recibo de compra de ValenFlag con el vale (voucher) que contiene la flag capturada.

```
THM{v4l3nt1n3_jwt_c00k13_t4mp3r_4dm1n_sh0p}
```

7. Conclusiones

1. El servicio expuesto en el puerto 5000 (aplicación Flask/Werkzeug) fue el vector de ataque principal; el puerto 22 (SSH) no presentó una vía de explotación directa en esta evaluación.
2. La enumeración de directorios con gobuster fue clave para descubrir la ruta oculta `/admin`, no enlazada desde la interfaz pública.
3. La vulnerabilidad explotada, según el nombre de la flag, fue una **manipulación de cookie/token JWT de sesión**, permitiendo escalar de usuario estándar a rol administrador sin validación adecuada del lado del servidor.
4. El acceso administrativo permitió comprar un artículo restringido ("solo personal") y obtener la flag final a través del recibo de compra.

8. Recomendaciones

- Verificar siempre la **firma** del JWT en el servidor y no confiar en claims (como `role` o `credits`) que puedan ser modificados por el cliente.
- Usar JWT firmados con algoritmos fuertes (ej. RS256) y rechazar explícitamente el algoritmo `none`.
- Restringir rutas administrativas (`/admin`) también mediante *rate limiting* y ocultarlas de descubrimiento trivial no es suficiente como única defensa; deben protegerse con control de acceso robusto en el backend.
- Revisar la lógica de autorización en endpoints de compra para validar permisos y saldo en el servidor, no solo en el cliente.